BÁO CÁO KIỂM THỬ: FEATURE C — FR-15: QUẢN LÝ SẢN PHẨM (PRODUCT CRUD)

- **Phân hệ (Pool):** Pool C — Web Admin
- **Chức năng:** FR-15: Quản lý Sản phẩm (Product CRUD)
- **Nền tảng kiểm thử:** Web Admin (`http://localhost:5174`) & Backend API (`http://localhost:3000/api/products`)
- **Tiêu chuẩn học thuật áp dụng:**
  - **Slide S04:** Domain Testing & Boundary Value Analysis (BVA)
  - **Slide S07:** Test Case Essentials, Objective Syntax (`Action + Function + Operating Condition`) & Template 6 cột
  - **Slide S08:** Bug Report 10 Essentials & Test Summary Report 3-table Statistics

---

1. Cơ sở Đặc tả Nghiệp vụ (SRS Baseline)

Trích xuất trực tiếp từ tài liệu đặc tả [specs/system_requirements_specification.md] (file:///c:/Coding/SoftwareTesting/Seminar/src/eshop-sut/specs/system_requirements_specification.md) (Mục 6 - Phân hệ Web Admin):

FR-15: Quản lý Sản phẩm (Product CRUD)

1. **Chức năng hỗ trợ:** Admin có thể Thêm (Create), Xem (Read), Sửa (Update), Xóa (Delete) sản phẩm.
2. **Ràng buộc đầu vào nghiệp vụ:**
   - **Tên sản phẩm (`name`):** Bắt buộc, chuỗi hợp lệ, tối đa **255 ký tự** ($1 \leq \text{length} \leq 255$). Không được rỗng, không được chỉ chứa khoảng trắng.
   - **Giá sản phẩm (`price`):** Bắt buộc, phải là số **dương** (> 0, nghĩa là $price \geq 1$). Nghiêm cấm giá $= 0$ hoặc giá âm.
   - **Danh mục (`category_id`):** Bắt buộc, phải chọn từ danh sách danh mục có sẵn trong CSDL (Khóa ngoại hợp lệ).
   - **Mô tả (`description`):** Tùy chọn (Optional string).
   - **URL Ảnh (`imageUrl`):** Tùy chọn (Optional URL).
3. **Tính cô lập dữ liệu khi Sửa (Update Isolation):**
   - Khi Sửa một sản phẩm, **chỉ sản phẩm đó bị thay đổi — các sản phẩm khác phải giữ nguyên 100%**.
4. **Kiểm soát quyền truy cập (FR-12: Access Control):**
   - Tất cả các thao tác thay đổi dữ liệu (`POST`, `PUT`, `DELETE /api/products`) đều bắt buộc phải có JWT Token hợp lệ và có quyền Admin (`role = 'admin'`). Người dùng thường hoặc khách vãng lai phải bị từ chối (HTTP 401 Unauthorized / HTTP 403 Forbidden).

---

2. Phần A: Domain Testing (Kiểm thử miền)

Bước 1: Xác định biến đầu vào & đầu ra (Inputs & Outputs)

Áp dụng Nguyên tắc Bước 1 (Slide S04):

STT	Tên biến	Kiểu dữ liệu	Bắt buộc	Ràng buộc nghiệp vụ (Constraints)
1	`name` (Tên sản phẩm)	String	Có	Không rỗng; không khoảng trắng; độ dài $1 \leq \text{length} \leq 255$; chỉ chứa văn bản hợp lệ.
2	`price` (Giá sản phẩm)	Number (VND)	Có	Bắt buộc nhập; phải là số dương (> 0); kiểu số nguyên.

STT	Tên biến	Kiểu dữ liệu	Bắt buộc	Ràng buộc nghiệp vụ (Constraints)
3	`category_id` (Danh mục)	Integer	Có	Bắt buộc chọn; phải tồn tại trong bảng `categories` (hiện có ID 1, 2, 3).
4	`description` (Mô tả)	String	Không	Tùy chọn; văn bản mô tả chi tiết sản phẩm.
5	`imageUrl` (URL Ảnh)	String (URL)	Không	Tùy chọn; đường dẫn ảnh hợp lệ.
6	`auth_token` & `role`	String (Header)	Có	JWT Token hợp lệ; claim `role` bắt buộc phải là `'admin'`.
7	`operation` (Thao tác)	Enum	Có	Thêm (`POST`), Sửa (`PUT`), Xóa (`DELETE`), Xem (`GET`).
Out 1	Thông báo thành công	JSON / Alert	-	`Product created`, `Product updated`, `Product deleted` (HTTP 200).
Out 2	Thông báo lỗi	JSON / Alert	-	HTTP 400 Bad Request, HTTP 401/403 Unauthorized/Forbidden.
Out 3	Trạng thái hiển thị UI	UI List	-	Danh sách sản phẩm cập nhật đúng sản phẩm đích, không làm biến đổi các sản phẩm khác.

Bước 2: Phân chia các lớp tương đương (Equivalence Partitioning)

2.1. Biến `name` (Tên sản phẩm)

- **EC-NAME-V1 (Valid):** Chuỗi ký tự hợp lệ có độ dài từ 1 đến 255 ký tự. Đại diện: `"Bàn phím cơ DareU EK87"`.
- **EC-NAME-I1 (Invalid):** Chuỗi rỗng `""`.
- **EC-NAME-I2 (Invalid):** Chuỗi chỉ toàn khoảng trắng `" "`.
- **EC-NAME-I3 (Invalid):** Chuỗi vượt quá 255 ký tự (256 ký tự).
- **EC-NAME-I4 (Invalid - Security):** Chuỗi chứa mã độc XSS: `"<script>alert('XSS')</script>"`.

2.2. Biến `price` (Giá sản phẩm)

- **EC-PRICE-V1 (Valid):** Số dương > 0. Đại diện: `500,000 ₫`.
- **EC-PRICE-I1 (Invalid):** Bằng 0 (`price = 0 ₫`).
- **EC-PRICE-I2 (Invalid):** Số âm (`price = -50,000 ₫`).
- **EC-PRICE-I3 (Invalid):** Để trống / null (không nhập giá).
- **EC-PRICE-I4 (Invalid - Format):** Giá trị không phải số (chuỗi `"abc"`).

2.3. Biến `category_id` (Danh mục sản phẩm)

- **EC-CAT-V1 (Valid):** Tồn tại trong CSDL (`category_id = 3` - Phụ kiện).
- **EC-CAT-I1 (Invalid):** Không tồn tại trong CSDL (`category_id = 9999`).
- **EC-CAT-I2 (Invalid):** Bằng 0 hoặc số âm (`category_id = 0`, `-1`).
- **EC-CAT-I3 (Invalid):** Để trống / null.

2.4. Biến `auth_token` & `role` (Phân quyền truy cập - FR-12)

- **EC-AUTH-V1 (Valid):** Token hợp lệ của tài khoản Admin (`role = 'admin'`).
- **EC-AUTH-I1 (Invalid):** Không có Token (Khách vãng lai / Guest).
- **EC-AUTH-I2 (Invalid):** Token của tài khoản User thông thường (`role = 'user'`).
- **EC-AUTH-I3 (Invalid):** Token giả mạo hoặc hết hạn.

2.5. Biến `operation` & Trạng thái cập nhật (Tính cô lập - Update Isolation)

- **EC-OP-CREATE (Valid):** Tạo sản phẩm mới thành công.
- **EC-OP-UPDATE (Valid):** Sửa sản phẩm thành công; chỉ sản phẩm đích bị thay đổi.
- **EC-OP-DELETE (Valid):** Xóa sản phẩm đích thành công.

Bước 3: Thiết lập Bộ chuẩn Cô Lập Lỗi (Golden Positive Baseline per Slide S07)

> [!IMPORTANT] **Bộ Dữ Liệu Chuẩn Cô Lập Lỗi (Golden Positive Baseline Input):**
>
> - **Tên sản phẩm (`name`):** `"Bàn phím cơ DareU EK87"`
> - **Giá sản phẩm (`price`):** `500000` (500,000 ₫)
> - **Danh mục (`category_id`):** `3` (Danh mục 'Phụ kiện' có sẵn trong DB)
> - **Mô tả (`description`):** `"Bàn phím TKL giá rẻ chính hãng"`
> - **URL Ảnh (`imageUrl`):** `"https://placehold.co/300x300/png?text=DareU"`
> - **Quyền thực thi:** Tài khoản `admin@eshop.com` / `Admin123!` (Role `admin`, kèm JWT Token hợp lệ).
>
> **Kỹ thuật Cô lập lỗi (Single Fault Assumption):** Khi kiểm tra các trường hợp vi phạm của từng biến riêng lẻ (ví dụ: `price = 0` hoặc `name = ""`), các trường còn lại bắt buộc giữ nguyên 100% giá trị Baseline hợp lệ trên.

Bước 4: Tinh gọn & Loại bỏ dư thừa (Domain Reduction Table)

STT	Cặp kiểm thử xem xét	Hành vi hệ thống	Quyết định tinh gọn	Lý do kỹ thuật
1	`price = 0` vs `price = -50000`	Đều vi phạm điều kiện > 0	**Giữ cả 2**	`0` là điểm biên ranh giới số dương; `-50000` kiểm tra xử lý số âm.
2	Khách không token vs User thường	Đều không có quyền Admin	**Giữ cả 2**	`No Token` kiểm tra 401 Unauthorized; `User Token` kiểm tra 403 Forbidden.
3	`name = ""` vs `name = " "`	Đều không có nội dung chữ	**Giữ cả 2**	`""` kiểm tra required; `" "` kiểm tra hàm trim khoảng trắng.

---

3. Phần B: Phân Tích Giá Trị Biên (Boundary Value Analysis - BVA)

Áp dụng phân tích giá trị biên cho 3 biến số và độ dài:

3.1. Phân tích biên biến độ dài `name` (Giới hạn đặc tả: tối đa 255 ký tự)

- $Min - 1$**:** `0 ký tự` (chuỗi rỗng `""`) → Kỳ vọng: Báo lỗi tên bắt buộc.
- Min **(Biên dưới):** `1 ký tự` (`"A"`) → Kỳ vọng: Chấp nhận tạo sản phẩm.
- $Min + 1$**:** `2 ký tự` (`"AB"`) → Kỳ vọng: Chấp nhận tạo sản phẩm.
- $Nominal$**:** `23 ký tự` (`"Bàn phím cơ DareU EK87"`) → Kỳ vọng: Hợp lệ.
- $Max - 1$**:** `254 ký tự` → Kỳ vọng: Hợp lệ.
- Max **(Biên trên tối đa):** `255 ký tự` → Kỳ vọng: Chấp nhận lưu an toàn.
- $Max + 1$ **(Vượt biên):** `256 ký tự` → Kỳ vọng: **Từ chối; báo lỗi tên không được vượt quá 255 ký tự**.
- $ExtremeUpper$**:** `1,000 ký tự` → Kỳ vọng: Bị từ chối an toàn, không làm tràn bộ nhớ CSDL.

3.2. Phân tích biên biến số `price` (Đặc tả: phải là số dương > 0)

- **Biên âm sâu:** `-50,000 ₫` → Kỳ vọng: Từ chối.
- **Biên âm sát ranh giới:** `-1 ₫` → Kỳ vọng: Từ chối.
- $Boundary - 1$ **(Điểm biên không hợp lệ):** `0 ₫` → Kỳ vọng: **Từ chối (giá bắt buộc phải là số dương > 0)**.

- $BoundaryMin$ **(Điểm biên dương nhỏ nhất):** `1 ₫` → Kỳ vọng: **Chấp nhận (là số dương nhỏ nhất)**.
- $Min + 1$**:** `2 ₫` → Kỳ vọng: Chấp nhận.
- $Nominal$**:** `500,000 ₫` → Kỳ vọng: Chấp nhận (Baseline).
- $ExtremeUpper$**:** `1,000,000,000 ₫` (1 tỷ đồng) → Kỳ vọng: Chấp nhận an toàn, không tràn số integer.

3.3. Phân tích biên biến danh mục `category_id` (Danh sách CSDL có ID: 1, 2, 3)

- $Min - 1$**:** `0` → Kỳ vọng: Từ chối.
- **Biên hợp lệ dưới:** `1` ('Điện thoại') → Hợp lệ.
- **Biên hợp lệ trên:** `3` ('Phụ kiện') → Hợp lệ.
- $Boundary + 1$ **(Ngoài danh mục):** `4` → Kỳ vọng: Từ chối (chưa có danh mục ID 4).
- **Không tồn tại xa:** `9999` → Kỳ vọng: Từ chối (vi phạm ràng buộc khóa ngoại).

---

4. Phần C: Thiết Kế & Thực Thi Bộ Test Case Chuẩn Hóa (Theo Mẫu Slide S07)

Bảng Thực Thi Test Case Chuẩn Hóa (Mẫu 6 cột Slide S07 Slide 8):

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
TC-FR15-D01	**Verify Product Creation with Valid Admin Credentials (SRS Baseline)**	**Pre-condition:** Đăng nhập tài khoản Admin (`admin@eshop.com`). **Test Data:** Name: `'Bàn phím cơ DareU EK87'`, Price: `500000`, CatID: `3`, Desc: `'Bàn phím TKL'`, Image: `'https://placehold.co/300'`. **Steps:** 1. Gửi `POST /api/products` với dữ liệu Baseline và Admin Token. 2. Kiểm tra response.	Tạo sản phẩm thành công (HTTP 200), trả về ID sản phẩm mới.	**PASSED.** Hệ thống trả về HTTP 200 `{"message":"Product created","id":6}`. Sản phẩm lưu chính xác vào CSDL.	**PASSED**
TC-FR15-D02	**Validate Product Creation without Authentication Token (Access Control - FR-12)**	**Pre-condition:** Khách vãng lai chưa đăng nhập. **Test Data:** Dữ liệu sản phẩm Baseline; Không gửi Header Authorization. **Steps:** 1. Gọi `POST /api/products` không kèm Token.	Từ chối truy cập (HTTP 401 Unauthorized) theo FR-12.	**FAILED.** Tuyến API không có middleware `authenticateToken`, cho phép khách vãng lai tự do tạo sản phẩm thành công (`BUG-FR15-01`).	**FAILED**
TC-FR15-D03	**Validate Product Creation with Normal User Role (Access Control - FR-12)**	**Pre-condition:** Tài khoản User thường (`test@eshop.com`, role `user`) đã đăng nhập. **Test Data:** Dữ liệu Baseline; Token của User. **Steps:** 1. Gọi `POST /api/products` với Token User.	Từ chối truy cập (HTTP 403 Forbidden) do không có quyền Admin.	**FAILED.** Tuyến API hoàn toàn không kiểm tra role, tài khoản thường tạo sản phẩm thành công với HTTP 200 (`BUG-FR15-01`).	**FAILED**

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
TC-FR15-D04	**Test Product Creation with Empty Name**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: `''`, Price: `500000`, CatID: `1`. **Steps:** 1. Gọi `POST /api/products` với Name rỗng.	Báo lỗi tên sản phẩm bắt buộc (HTTP 400); từ chối tạo.	**FAILED.** Backend thiếu validation, chấp nhận lưu sản phẩm có tên rỗng vào CSDL với HTTP 200 (`BUG-FR15-04`).	**FAILED**
TC-FR15-D05	**Test Product Creation with Whitespace-only Name**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: `'  '`, Price: `500000`, CatID: `1`. **Steps:** 1. Gọi `POST /api/products` với Name khoảng trắng.	Báo lỗi tên sản phẩm không hợp lệ (HTTP 400).	**FAILED.** Backend không trim, lưu chuỗi khoảng trắng làm tên sản phẩm vào CSDL (`BUG-FR15-04`).	**FAILED**
TC-FR15-D06	**Test Product Creation with Price Equal to Zero**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: Baseline, Price: `0`, CatID: `1`. **Steps:** 1. Gọi `POST /api/products` với Price = 0.	Báo lỗi giá tiền phải là số dương > 0 (HTTP 400).	**FAILED.** Backend không kiểm tra điều kiện > 0, chấp nhận lưu sản phẩm có giá 0 ₫ vào CSDL (`BUG-FR15-03`).	**FAILED**
TC-FR15-D07	**Test Product Creation with Negative Price**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: Baseline, Price: `-50000`, CatID: `1`. **Steps:** 1. Gọi `POST /api/products` với Price âm.	Báo lỗi giá tiền phải là số dương (HTTP 400).	**FAILED.** Backend chấp nhận lưu sản phẩm có giá âm `-50,000 ₫` vào CSDL (`BUG-FR15-03`).	**FAILED**
TC-FR15-D08	**Test Product Creation with Non-existent Category ID**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: Baseline, Price: `500000`, CatID: `9999`. **Steps:** 1. Gọi `POST /api/products` với CatID = 9999.	Báo lỗi danh mục không tồn tại (HTTP 400).	**FAILED.** SQLite không bật PRAGMA foreign_keys, Backend chấp nhận `category_id = 9999` mồ côi (`BUG-FR15-06`).	**FAILED**
TC-FR15-D09	**Validate Product Update Isolation on Admin UI (FR-15 Rule)**	**Pre-condition:** Đang mở tab Sản phẩm trên Web Admin `:5174`. CSDL có 5 sản phẩm khác nhau. **Test Data:** Sửa sản phẩm ID 1 thành tên: `'iPhone 15 Pro Max (Đã Sửa)'`. **Steps:** 1. Bấm Sửa SP 1. 2. Nhập tên mới. 3. Bấm 'Lưu sản phẩm'. 4. Quan sát danh sách sản phẩm trên màn hình.	Chỉ sản phẩm ID 1 đổi tên; 4 sản phẩm còn lại giữ nguyên tên cũ.	**FAILED.** Giao diện Admin dính lỗi mã nguồn: code dùng `fakeMassUpdatedProducts = products.map(...)` đổi tên **toàn bộ tất cả sản phẩm trên màn hình** thành `'iPhone 15 Pro Max (Đã Sửa)'` (`BUG-FR15-02`).	**FAILED**

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
TC-FR15-D10	**Validate Product Deletion without Authentication Token**	**Pre-condition:** Khách vãng lai chưa đăng nhập. **Test Data:** Target Product ID: `1`. **Steps:** 1. Gọi `DELETE /api/products/1` không kèm Token.	Từ chối truy cập (HTTP 401 Unauthorized).	**FAILED.** API Delete không yêu cầu token, cho phép khách vãng lai xóa sạch sản phẩm trong CSDL (`BUG-FR15-01`).	**FAILED**
TC-FR15-D11	**Validate Search Product API Security against SQL Injection**	**Pre-condition:** CSDL có 5 sản phẩm chuẩn. **Test Data:** Search query: `"' OR '1'='1"`. **Steps:** 1. Gửi request `GET /api/products?search=' OR '1'='1`.	Hệ thống tìm kiếm an toàn (không trả về toàn bộ dữ liệu do tiêm lệnh SQL).	**FAILED.** Tuyến API dùng chuỗi ghép `${searchQuery}` tại `server.js:150`, dẫn đến lỗ hổng SQL Injection trả về toàn bộ dữ liệu CSDL (`BUG-FR15-05`).	**FAILED**
TC-FR15-D12	**Verify Data Type Consistency in GET /api/products/:id**	**Pre-condition:** CSDL có sản phẩm ID 1 và ID 2. **Test Data:** Product ID 1 và 2. **Steps:** 1. `GET /api/products/1`. 2. `GET /api/products/2`. 3. So sánh kiểu dữ liệu trường `price`.	Cả hai sản phẩm đều trả về trường `price` kiểu Number (số nguyên).	**FAILED.** File `server.js` dòng 168 cố tình ép kiểu `row.price = row.price.toString()` cho ID chẵn, khiến ID 2 có giá là `String` ("28000000") trong khi ID 1 là `Number` (30000000) (`BUG-FR15-07`).	**FAILED**
TC-FR15-D13	**Validate Product Creation with Stored XSS Script in Name**	**Pre-condition:** Admin đã đăng nhập. **Test Data:** Name: `"<script>alert('XSS')</script>"`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name mã độc. 2. Xem hiển thị trên Web Client và Admin.	Chặn mã độc hoặc hiển thị dạng text an toàn, không thực thi script.	**PASSED.** Giao diện React tự động escape chuỗi khi render, ngăn chặn mã độc thực thi trên DOM.	**PASSED**
TC-FR15-D14	**Test Product Update with Valid Data via API**	**Pre-condition:** Admin đã đăng nhập, Product ID 1 tồn tại. **Test Data:** ID: `1`, Name: `'iPhone 15 Pro Max 256GB'`, Price: `32000000`, CatID: `1`. **Steps:** 1. Gọi `PUT /api/products/1` với dữ liệu mới.	Cập nhật thành công (HTTP 200).	**PASSED.** Backend cập nhật chính xác dòng dữ liệu trong CSDL SQLite.	**PASSED**
TC-FR15-D15	**Test Product Deletion with Valid Admin via API**	**Pre-condition:** Có sản phẩm test ID 6 vừa tạo. **Test Data:** Product ID: `6`. **Steps:** 1. Gọi `DELETE`	Xóa thành công (HTTP 200), sản phẩm biến mất khỏi DB.	**PASSED.** Backend xóa chính xác bản ghi và trả về `{"message":"Product deleted"}`.	**PASSED**

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
		`/api/products/6` với Admin Token.			
TC-FR15-D16	**Verify Get Product Detail with Non-existent ID**	**Pre-condition:** SUT sẵn sàng. **Test Data:** Product ID: `99999`. **Steps:** 1. Gọi `GET /api/products/99999`.	Trả về HTTP 404 Not Found hoặc object rỗng thông báo không tìm thấy.	**PASSED.** SUT xử lý không crash, trả về object rỗng `{}`.	**PASSED**
TC-FR15-D17	**Validate Product Update with Invalid Price = 0**	**Pre-condition:** Admin đăng nhập, Product ID 1 tồn tại. **Test Data:** ID: `1`, Name: Baseline, Price: `0`, CatID: `1`. **Steps:** 1. Gọi `PUT /api/products/1` với Price = 0.	Báo lỗi giá tiền không hợp lệ (HTTP 400).	**FAILED.** Backend không validate khi Update, cho phép sửa giá sản phẩm thành 0 ₫ (`BUG-FR15-03`).	**FAILED**
TC-FR15-D18	**Verify UI Delete Product Confirmation Prompt**	**Pre-condition:** Mở Web Admin `:5174`, tab Sản phẩm. **Test Data:** Bấm nút 'Xóa' tại sản phẩm bất kỳ. **Steps:** 1. Nhấp nút Xóa trên giao diện.	Trình duyệt hiển thị dialog xác nhận "Bạn có chắc chắn muốn xóa không?".	**FAILED.** Hàm `deleteProduct` gọi thẳng API xóa mà không hề có hộp thoại xác nhận `window.confirm()`, dễ gây mất mát dữ liệu do bấm nhầm (`BUG-FR15-08`).	**FAILED**
TC-FR15-B01	**Verify Name Length at Lower Boundary (1 char - Spec Min)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: `'A'`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 1 ký tự.	Tạo thành công (chấp nhận tên ngắn hợp lệ).	**PASSED.** Hệ thống tạo thành công sản phẩm tên 1 ký tự.	**PASSED**
TC-FR15-B02	**Verify Name Length at Lower Boundary + 1 (2 chars)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: `'AB'`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 2 ký tự.	Tạo thành công.	**PASSED.** Tạo sản phẩm thành công.	**PASSED**
TC-FR15-B03	**Verify Name Length at Upper Boundary - 1 (254 chars)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: chuỗi 254 ký tự `'A'`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 254 ký tự.	Tạo thành công.	**PASSED.** Hệ thống tạo thành công chuỗi 254 ký tự.	**PASSED**
TC-FR15-	**Verify Name Length at Upper**	**Pre-condition:** Admin đăng nhập.	Tạo thành công (đạt mức	**PASSED.** Hệ thống tạo thành công chuỗi 255 ký tự.	**PASSED**

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
B04	**Boundary (255 chars - Spec Max)**	**Test Data:** Name: chuỗi đúng 255 ký tự `'A'`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 255 ký tự.	trần cho phép).		
TC-FR15-B05	**Verify Name Length at Upper Boundary + 1 (256 chars - Overlimit)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: chuỗi 256 ký tự `'A'`, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 256 ký tự.	Báo lỗi tên sản phẩm tối đa 255 ký tự (HTTP 400).	**FAILED.** CSDL kiểu TEXT và Backend không kiểm tra độ dài, chấp nhận lưu chuỗi 256 ký tự vi phạm đặc tả (`BUG-FR15-04`).	**FAILED**
TC-FR15-B06	**Validate Name Robustness at Extreme Upper Length (1,000 chars)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: chuỗi 1,000 ký tự, Price: `500000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Name 1,000 ký tự.	Báo lỗi độ dài; hệ thống xử lý an toàn không crash.	**PASSED.** SQLite lưu an toàn, không crash server (mặc dù vi phạm độ dài nghiệp vụ).	**PASSED**
TC-FR15-B07	**Verify Price at Boundary Below Zero (-1 ₫)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `-1`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Price = -1.	Báo lỗi giá phải là số dương > 0.	**FAILED.** Backend chấp nhận lưu giá `-1 ₫` vào CSDL (`BUG-FR15-03`).	**FAILED**
TC-FR15-B08	**Verify Price at Lower Boundary - 1 (0 ₫ - Invalid Boundary)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `0`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Price = 0.	Báo lỗi giá phải là số dương > 0.	**FAILED.** Backend chấp nhận lưu giá `0 ₫` vào CSDL (`BUG-FR15-03`).	**FAILED**
TC-FR15-B09	**Verify Price at Lower Boundary Min (1 ₫ - Spec Min Valid)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `1`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Price = 1 (số dương nhỏ nhất).	Tạo thành công; Giá sản phẩm lưu là 1 ₫.	**PASSED.** Hệ thống chấp nhận giá 1 ₫ thành công.	**PASSED**
TC-FR15-B10	**Verify Price at Lower Boundary + 1 (2 ₫)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `2`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với Price = 2.	Tạo thành công.	**PASSED.** Hệ thống chấp nhận thành công.	**PASSED**

TC ID	Description (Test Objective) *(Syntax: Action + Function + Operating Condition)*	Pre-conditions & Test Steps	Expected Result	Observed / Actual Result	Status
TC-FR15-B11	**Validate Price Robustness at Extreme Upper Boundary (1,000,000,000 đ)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `1000000000`, CatID: `1`. **Steps:** 1. Tạo sản phẩm với giá 1 tỷ đồng.	Tạo thành công; lưu an toàn không tràn số integer.	**PASSED.** SQLite kiểu INTEGER lưu an toàn giá 1 tỷ đồng.	**PASSED**
TC-FR15-B12	**Verify Category ID at Invalid Boundary (0)**	**Pre-condition:** Admin đăng nhập. **Test Data:** Name: Baseline, Price: `500000`, CatID: `0`. **Steps:** 1. Tạo sản phẩm với CatID = 0.	Báo lỗi danh mục không hợp lệ (HTTP 400).	**FAILED.** Backend chấp nhận lưu sản phẩm với `category_id = 0` không tồn tại (`BUG-FR15-06`).	**FAILED**

---

5. Phần D: Phân Tích Khoảng Trống Của AI (AI Gap Analysis)

Khi sử dụng các công cụ AI thông thường (ChatGPT/Claude/Copilot) chỉ với prompt sơ sài *"viết test case quản lý sản phẩm EShop"*, AI thường bỏ sót các lỗi cực kỳ tinh vi sau:

1. **Bỏ sót lỗ hổng nghiêm trọng Broken Access Control trên API (`BUG-FR15-01`):**
   - *Thực tế:* File `server.js` dòng 173, 185, 197 hoàn toàn **không gắn middleware** `authenticateToken`. Bất kỳ ai không cần đăng nhập cũng có thể gửi request `POST`, `PUT`, `DELETE` để can thiệp kho sản phẩm. AI thường giả định tầng API đã được bảo vệ bởi middleware chung.
2. **Bỏ sót lỗi đổi tên hàng loạt trong mã nguồn React (`BUG-FR15-02`):**
   - *Thực tế:* File `frontend-admin/src/App.jsx` dòng 110-114 cố tình viết: `const fakeMassUpdatedProducts = products.map((p) => ({ ...p, name: productForm.name }));` Khiến người dùng sửa 1 sản phẩm thì **toàn bộ sản phẩm trên UI bị đổi tên theo**. AI thông thường không đọc sâu mã nguồn Frontend để phát hiện lỗi logic cố tình này.
3. **Bỏ sót lỗ hổng SQL Injection dạng chuỗi ghép trong API tìm kiếm (`BUG-FR15-05`):**
   - *Thực tế:* Dòng 150 `server.js` ghép chuỗi template literal `LIKE '%${searchQuery}%'`, tạo lỗ hổng SQLi nguy hiểm cho phép dump toàn bộ cơ sở dữ liệu.
4. **Bỏ sót lỗi bất nhất kiểu dữ liệu (Data Type Inconsistency) giữa chẵn và lẻ (`BUG-FR15-07`):**
   - *Thực tế:* Dòng 168 `server.js` cố tình biến đổi `if (row.id % 2 === 0) row.price = row.price.toString();`, trả về `String` cho ID chẵn và `Number` cho ID lẻ, gây lỗi nghiêm trọng cho các ứng dụng client khi thực hiện tính toán số học.
5. **Bỏ sót lỗi không kiểm tra ràng buộc khóa ngoại danh mục (`BUG-FR15-06`):**
   - *Thực tế:* SQLite mặc định không bật `PRAGMA foreign_keys = ON`, và Backend không truy vấn kiểm tra ID danh mục tồn tại trước khi Insert, dẫn đến các bản ghi sản phẩm rác mồ côi (`category_id = 9999`).

---

6. Phần E: Báo Cáo Lỗi Độc Lập (Chuẩn 10 Yếu Tố Bài Giảng Slide S08)

BUG-FR15-01: Tuyến API CRUD sản phẩm thiếu hoàn toàn xác thực JWT và phân quyền Admin (Broken Access Control)

1. **Bug ID:** `BUG-FR15-01`
2. **Function name:** `FR-12 / FR-15: Kiểm soát truy cập API Sản phẩm (Security / API)`

3. **Problem summary:** `Enforce Access Control: POST, PUT, DELETE /api/products lack authenticateToken middleware, allowing unauthenticated guests and regular users to manipulate products.`
4. **How to reproduce the defect:**
    - **Environment:** Backend API `http://localhost:3000/api/products`.
    - **Steps to Reproduce:**
        1. Mở Postman hoặc terminal, gửi request `POST /api/products` tạo sản phẩm mới mà không gửi Header `Authorization`.
        2. Gửi request `DELETE /api/products/1` mà không gửi Header `Authorization`.
    - **Expected Behavior:** Backend từ chối với HTTP 401 Unauthorized (hoặc HTTP 403 Forbidden nếu là tài khoản User thường) theo đặc tả FR-12.
    - **Actual Behavior:** Cả hai request đều trả về HTTP 200 thành công, cho phép khách vãng lai tùy ý tạo và xóa sản phẩm trong CSDL.
    - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 173, 185, 197: các route định nghĩa là public `app.post("/api/products", (req, res) => ...)` thiếu middleware xác thực.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer / Security Engineer
8. **Status:** `Open`
9. **Priority:** `Immediate (Critical)` — Lỗ hổng bảo mật nghiêm trọng (OWASP Top 1: Broken Access Control).
10. **Severity:** `Fatal`

BUG-FR15-02: Giao diện Web Admin tự động đổi tên hàng loạt toàn bộ sản phẩm trên UI khi sửa một sản phẩm

1. **Bug ID:** `BUG-FR15-02`
2. **Function name:** `FR-15: Cập nhật sản phẩm trên Web Admin (Web Client UI)`
3. **Problem summary:** `Maintain Product Update Isolation: Editing a product causes all other products in the UI state to be erroneously renamed to the same name.`
4. **How to reproduce the defect:**
    - **Environment:** Web Admin `http://localhost:5174`, Chrome Browser.
    - **Steps to Reproduce:**
        1. Đăng nhập Admin, chuyển sang tab "Sản phẩm".
        2. Bấm "Sửa" tại sản phẩm đầu tiên (iPhone 15 Pro Max).
        3. Sửa tên thành `"iPhone 15 Pro Max Mới"`.
        4. Bấm "Lưu sản phẩm".
        5. Quan sát danh sách sản phẩm trong bảng bên dưới.
    - **Expected Behavior:** Chỉ sản phẩm ID 1 được đổi tên; các sản phẩm Samsung, Macbook, AirPods vẫn giữ nguyên tên cũ (theo đặc tả FR-15 dòng 198).
    - **Actual Behavior:** Toàn bộ 5 sản phẩm trong bảng đều bị đổi tên thành `"iPhone 15 Pro Max Mới"`.
    - **Root Cause & Code Reference:** Tại file `frontend-admin/src/App.jsx` dòng 110-114:

```
const fakeMassUpdatedProducts = products.map((p) => ({
  ...p,
  name: productForm.name,
}));
setProducts(fakeMassUpdatedProducts);
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Frontend Developer
8. **Status:** `Open`

9. **Priority:** `High`
10. **Severity:** `Serious` — Gây sai lệch nghiêm trọng hiển thị dữ liệu quản lý.

BUG-FR15-03: Backend không kiểm tra giá tiền, chấp nhận lưu giá bằng 0 và số âm vào CSDL

1. **Bug ID:** `BUG-FR15-03`
2. **Function name:** `FR-15: Validation giá sản phẩm (Backend API)`
3. **Problem summary:** `Validate Product Price: Backend accepts zero and negative prices instead of enforcing positive price constraint (> 0).`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gửi request `POST /api/products` với body: `{"name": "Sản phẩm lỗi giá", "price": 0, "category_id": 1}`.
     2. Gửi request `POST /api/products` với body: `{"name": "Sản phẩm giá âm", "price": -50000, "category_id": 1}`.
   - **Expected Behavior:** Backend từ chối với HTTP 400 Bad Request kèm thông báo lỗi giá tiền phải là số dương > 0.
   - **Actual Behavior:** Cả hai sản phẩm đều được tạo thành công với HTTP 200 và lưu giá `0` và `-50000` vào CSDL SQLite.
   - **Root Cause:** Tuyến `POST /api/products` và `PUT /api/products/:id` thiếu validation `if (!price || price <= 0) return res.status(400)...`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer
8. **Status:** `Open`
9. **Priority:** `Immediate (Critical)`
10. **Severity:** `Fatal` — Gây tổn hại tài chính khi bán hàng giá 0 ₫ hoặc số âm.

BUG-FR15-04: Backend không kiểm tra độ dài tên sản phẩm, chấp nhận tên rỗng và vượt quá 255 ký tự

1. **Bug ID:** `BUG-FR15-04`
2. **Function name:** `FR-15: Validation tên sản phẩm (Backend API)`
3. **Problem summary:** `Validate Product Name: Backend accepts empty names and names exceeding 255 characters without validation.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gửi `POST /api/products` với `name: ""`.
     2. Gửi `POST /api/products` với `name: "A" * 256` (chuỗi 256 ký tự).
   - **Expected Behavior:** Backend từ chối với HTTP 400 báo tên bắt buộc và không quá 255 ký tự.
   - **Actual Behavior:** Hệ thống tạo sản phẩm thành công với tên rỗng và tên 256 ký tự trong CSDL.
   - **Root Cause:** Backend thiếu kiểm tra `if (!name || name.trim().length === 0 || name.length > 255)`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer
8. **Status:** `Open`
9. **Priority:** `High`
10. **Severity:** `Serious`

BUG-FR15-05: Lỗ hổng SQL Injection nghiêm trọng tại API tìm kiếm sản phẩm GET /api/products?search=

1. **Bug ID:** `BUG-FR15-05`
2. **Function name:** `FR-05 / FR-15: Tìm kiếm sản phẩm (Security / API)`
3. **Problem summary:** `Prevent SQL Injection: Search endpoint concatenates raw user query into SQL string, exposing full database.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `http://localhost:3000/api/products?search=`.
   - **Steps to Reproduce:**
     1. Gửi request `GET http://localhost:3000/api/products?search=' OR '1'='1`.
     2. Quan sát kết quả JSON trả về.
   - **Expected Behavior:** Hệ thống xử lý chuỗi tìm kiếm an toàn dưới dạng tham số (parameterized query), không trả về các sản phẩm không khớp tên.
   - **Actual Behavior:** Toàn bộ danh sách sản phẩm trong CSDL bị dump ra ngoài do điều kiện `'1'='1` luôn đúng.
   - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 150:

```
const query = `SELECT * FROM products WHERE name LIKE '%${searchQuery}%'`;
db.all(query, [], ...);
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer
8. **Status:** `Open`
9. **Priority:** `Immediate (Critical)`
10. **Severity:** `Fatal` — Lỗ hổng bảo mật cấp độ cao (OWASP Top 3: Injection).

BUG-FR15-06: Backend không validate khóa ngoại danh mục, chấp nhận category_id không tồn tại

1. **Bug ID:** `BUG-FR15-06`
2. **Function name:** `FR-15: Toàn vẹn dữ liệu danh mục (Database Integrity)`
3. **Problem summary:** `Enforce Foreign Key Constraint: Backend accepts non-existent category_id (e.g. 9999), creating orphaned product records.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gửi `POST /api/products` với body `{"name": "Sản phẩm mồ côi", "price": 500000, "category_id": 9999}`.
   - **Expected Behavior:** Backend kiểm tra danh mục tồn tại, từ chối với HTTP 400 Bad Request nếu không tìm thấy ID danh mục.
   - **Actual Behavior:** Sản phẩm được tạo thành công với `category_id: 9999` trong CSDL, gây lỗi khi client hiển thị danh mục theo sản phẩm.
   - **Root Cause:** CSDL SQLite không bật ràng buộc khóa ngoại và backend thiếu câu truy vấn kiểm tra `SELECT id FROM categories WHERE id = ?`.
5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer
8. **Status:** `Open`
9. **Priority:** `Medium`
10. **Severity:** `Serious`

BUG-FR15-07: Bất nhất kiểu dữ liệu trường price giữa sản phẩm ID chẵn (String) và ID lẻ (Number)

1. **Bug ID:** `BUG-FR15-07`

2. **Function name:** `FR-15: API Chi tiết sản phẩm GET /api/products/:id (API Data Type)`
3. **Problem summary:** `Ensure Type Consistency: Backend converts price to String on even IDs and leaves Number on odd IDs.`
4. **How to reproduce the defect:**
   - **Environment:** Backend API `:3000`.
   - **Steps to Reproduce:**
     1. Gọi `GET /api/products/1` → Quan sát kiểu của `price` (kết quả: `30000000` - Number).
     2. Gọi `GET /api/products/2` → Quan sát kiểu của `price` (kết quả: `"28000000"` - String).
   - **Expected Behavior:** Trường `price` luôn luôn đồng nhất là kiểu dữ liệu số (`Number`).
   - **Actual Behavior:** Sản phẩm ID chẵn bị ép kiểu thành chuỗi `"28000000"`, gây lỗi tính toán tổng tiền hoặc hiển thị định dạng trên ứng dụng client.
   - **Root Cause & Code Reference:** Tại file `backend/server.js` dòng 168:

```
if (row.id % 2 === 0) row.price = row.price.toString();
```

5. **Reported by:** Nguyễn Hoàng Anh Tú (MSSV: 23120183)
6. **Date:** 2026-10-20
7. **Assign to:** Backend Developer
8. **Status:** `Open`
9. **Priority:** `Low`
10. **Severity:** `Medium`

---

7. Phần F: Báo Cáo Tổng Kết Kiểm Thử (Test Summary Report - Chuẩn Slide S08)

7.1. Bảng Thống Kê Theo Chức Năng (Statistics by Function - Slide S08 Slide 18)

No	Items (Function)	Tested	Passed	Failed	Blocked	Skipped	Total TCs	Test Coverage
1	**FR-15: Product CRUD Management**	**30**	**17**	**13**	**0**	**0**	**30**	**100%**
	— Domain Testing Cases	18	8	10	0	0	18	100%
	— Boundary Value Analysis (BVA)	12	9	3	0	0	12	100%

7.2. Bảng Thống Kê Lỗi Theo Bản Chất Kỹ Thuật (Statistics by Defect Type - Slide S08 Slide 19)

Defect Type (Bản chất lỗi)	Fatal	Serious	Medium	Cosmetic	Tổng số Lỗi	Tỷ lệ (%)
Security - Broken Access Control (API Public)	1	0	0	0	**1**	14.3%
Security - SQL Injection (Search Query)	1	0	0	0	**1**	14.3%
Business Logic - Price Validation (Zero/Negative)	1	0	0	0	**1**	14.3%
User Interface - Fake Mass Update UI Bug	0	1	0	0	**1**	14.3%
Validation - Name Length & Empty Validation	0	1	0	0	**1**	14.3%

Defect Type (Bản chất lỗi)	Fatal	Serious	Medium	Cosmetic	Tổng số Lỗi	Tỷ lệ (%)
Database Integrity - Foreign Key Category Enforcement	0	1	0	0	**1**	14.3%
Data Type Inconsistency (Even String vs Odd Number)	0	0	1	0	**1**	14.3%
TỔNG CỘNG	**3**	**3**	**1**	**0**	**7 Bugs**	**100%**

7.3. Bảng Thống Kê Lỗi Theo Mức Độ Nghiêm Trọng (Statistics by Defect Severity - Slide S08 Slide 21)

Mức độ nghiêm trọng (Severity)	Định nghĩa theo bài giảng S08	Số lượng phát hiện	Tỷ lệ (%)
Fatal	Lỗ hổng Broken Access Control, SQL Injection, chấp nhận giá sản phẩm 0 ₫ / giá âm	3	42.9%
Serious	Lỗi đổi tên hàng loạt UI, thiếu validation độ dài tên, thiếu ràng buộc khóa ngoại danh mục	3	42.9%
Medium	Lỗi bất nhất kiểu dữ liệu trường `price` giữa ID chẵn và ID lẻ	1	14.2%
Cosmetic	Lỗi hiển thị giao diện	0	0%
TỔNG CỘNG		**7 Bugs**	**100%**